



MASTG

- 0016: Testing Random Number Generation
- MASTG-TEST-0204: Insecure Random API Usage
- MASTG-TEST-0205: Non-random Sources Usage
- MASTG-TEST-0208: Insufficient Key Sizes
- MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code
- MASTG-TEST-0221: Broken Symmetric Encryption Algorithms
- MASTG-TEST-0232: Broken Symmetric Encryption Modes
- MASTG-TEST-0307: References to Asymmetric Key Pairs

L1

L2

ANDROID

MASWE-0014

TEST



MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code

Overview

In this test case, we will look for the use of hardcoded keys in Android applications. To do this, we need to focus on the cryptographic implementations of hardcoded keys. The Java Cryptography Architecture (JCA) provides the `SecretKeySpec` class, which allows you to create a `SecretKey` from a byte array.

Steps

- Use either *Static Analysis on Android* with a tool such as *semgrep* or *Method Tracing* (dynamic analysis) with a tool like *Frida (Android)* to identify all the instances of symmetric key encryption in code and look for uses of the hardcoded cryptographic keys.

Observation

The output should contain a list of locations where hardcoded keys are used.

Evaluation

The test case fails if you find any hardcoded keys that are used in security-sensitive contexts.

Demos

MASTG-DEMO-0017: Use of Hardcoded AES Key in SecretKeySpec with semgrep